

HOCH

Rechnungs-/IBAN-Manipulation (BEC)

IT · Betrug / E-Mail-Kompromittierung

Versendete Rechnungen kommen mit fremder IBAN an; eingehende PDFs tragen alle dieselbe (auslaendische) IBAN.

Sofortmassnahmen

1. Zahlungsstopp veranlassen
2. Beweise NICHT veraendern
3. Verdaechtige Postfachregel/Weiterleitung gefunden?

Meldewege & Fristen

- Geschaeftsleitung / Krisenstab [sofort]
- Hausbank + Empfaengerbank [sofort (Zeit kritisch)]
- Kunden / Lieferanten [sofort]
- Polizei – Zentrale Ansprechstelle Cybercrime (ZAC) [zeitnah]
- Datenschutz-Aufsichtsbehoerde / DSB [binnen 72 h ab Kenntnis (Art. 33 DSGVO)]

Beweise zuerst (Volatilitaet)

- Verdaechtige E-Mails (.eml/.msg + Header) (mittel)
- PDF-Paare (gesendet/zugestellt) (niedrig)
- M365/Exchange Audit + Regeln (mittel)
- Endpoint-Triage Quellrechner (hoch)

IR-Pilot Einsatzkarte · Reihenfolge: Sicherheit > fluechtige Beweise > Eindaeimmung. Asservate hashen + Chain of Custody.

KRITISCH

Umspannwerk 300 kV – physischer Einbruch + OT-Manipulationsverdacht

OT/ICS · Energie (KRITIS)

Einbruch ohne Diebstahl/Schaden; Verdacht auf Cyber-Manipulation, ggf. an Schutzgeraeten (Schutzrelais).

Sofortmassnahmen

1. Gefahr fuer Leib/Leben oder Netzstabilitaet?
2. Leitstelle/Netzbetreiber einbinden
3. Tatort sichern (physisch + digital)

Meldewege & Fristen

- Geschaeftsleitung / Krisenstab [sofort]
- BSI (+ BNetzA, CERT) [unverzueglich (§8b BSIG / sektorspezifisch)]
- Polizei – Zentrale Ansprechstelle Cybercrime (ZAC) [zeitnah]
- Datenschutz-Aufsichtsbehoerde / DSB [binnen 72 h ab Kenntnis (Art. 33 DSGVO)]

Beweise zuerst (Volatilitaet)

- Relais-Configs/Events (COMTRADE) (mittel)
- Engineering-Workstation Image (hoch)
- OT-Netzwerk-Capture (pcap) (hoch)
- Zutritts-/Videologs (mittel)

IR-Pilot Einsatzkarte · Reihenfolge: Sicherheit > fluechtige Beweise > Eindaeimmung. Asservate hashen + Chain of Custody.

KRITISCH

Bahnstellwerk - aktiver Eindringling (Maus bewegt sich)

OT/ICS · Bahn (Safety-kritisch)

Schaltmeister sieht Mauszeiger sich ohne Eingabe bewegen - aktiver Fernzugriff auf einem sicherheitsrelevanten Bedienplatz.

Sofortmassnahmen

1. Betriebssicherheit zuerst
2. Beobachten, nicht stoeren
3. Eingaben am Bedienplatz vermeiden
4. Aktive Manipulation sicherheitsrelevant?

Meldewege & Fristen

- Geschaeftsleitung / Krisenstab [sofort]
- Eisenbahn-Bundesamt (EBA) + BSI [unverzueglich]
- Polizei - Zentrale Ansprechstelle Cybercrime (ZAC) [zeitnah]

Beweise zuerst (Volatilitaet)

- Bildschirm-Aufnahme Live-Angriff (hoch)
- RAM-Abbild Bedien-PC (hoch)
- Netzwerk-Capture C2 (hoch)
- Disk-Image Bedien-PC (mittel)

IR-Pilot Einsatzkarte · Reihenfolge: Sicherheit > fluechtige Beweise > Eindaeimmung. Asservate hashen + Chain of Custody.

KRITISCH

Ransomware - alles verschlüsselt (Kasse, Buero, Klima)

IT/OT · Ransomware

Flaechendeckende Verschlüsselung von POS, Buero-IT bis Gebaeude-/Klimasteuerung.

Sofortmassnahmen

1. Sofort isolieren – nicht ausschalten
2. Backups intakt & getrennt?
3. Keine vorschnelle Zahlung

Meldewege & Fristen

- Geschaeftsleitung / Krisenstab [sofort]
- Polizei – Zentrale Ansprechstelle Cybercrime (ZAC) [zeitnah]
- Intern / No More Ransom [vor Wiederherstellung]
- Datenschutz-Aufsichtsbehoerde / DSB [binnen 72 h ab Kenntnis (Art. 33 DSGVO)]
- Mitarbeiter / Kunden / Oeffentlichkeit [nach Freigabe]

Beweise zuerst (Volatilitaet)

- RAM-Abbild Patient Zero (hoch)
- Endpoint-Triage-Pakete (hoch)
- Zentrale Logs (mittel)
- Exfil-Indikatoren (mittel)

IR-Pilot Einsatzkarte · Reihenfolge: Sicherheit > fluechtige Beweise > Eindaeimmung. Asservate hashen + Chain of Custody.

KRITISCH

Active Directory - Brute Force auf Domain-Admin, dann erfolgreich

IT · Identität / AD-Kompromittierung

IDS meldet ~400 fehlgeschlagene Logins gegen einen Domain-Admin in der Produktion, danach ein erfolgreicher.

Sofortmassnahmen

1. Kompromittiertes DA-Konto sofort sperren
2. Quell-Host isolieren
3. Tier-0 schuetzen

Meldewege & Fristen

- Geschaeftsleitung / Krisenstab [sofort]
- Polizei – Zentrale Ansprechstelle Cybercrime (ZAC) [zeitnah]
- Datenschutz-Aufsichtsbehoerde / DSB [binnen 72 h ab Kenntnis (Art. 33 DSGVO)]
- OT-/Anlagenverantwortliche [sofort]

Beweise zuerst (Volatilitaet)

- DC-Security-Logs (mittel)
- Quell-Host Triage/RAM (hoch)
- NTDS/DCSync-Indikatoren (mittel)
- AD-Aenderungsspuren (mittel)

IR-Pilot Einsatzkarte · Reihenfolge: Sicherheit > fluechtige Beweise > Eindaeimmung. Asservate hashen + Chain of Custody.

HOCH

Supply-Chain - Wartungslaptop mit Malware (4 MW Solar + 500 kW Speicher)

OT/ICS · Energie / Lieferkette

Lieferant meldet: Laptop des gestrigen Wartungstechnikers hat Malware mit C2 nach Russland.

Sofortmassnahmen

1. Anlage als potenziell kompromittiert behandeln
2. Fernzugriff der Anlage einschränken
3. Hinweise auf Manipulation der Steuerung?

Meldewege & Fristen

- Geschäftsleitung / Krisenstab [sofort]
- Lieferant / Wartungsfirma [sofort]
- BSI (+ BNetzA, CERT) [unverzüglich (§8b BSIG / sektorspezifisch)]
- Polizei – Zentrale Ansprechstelle Cybercrime (ZAC) [zeitnah]

Beweise zuerst (Volatilität)

- Techniker-Laptop Image/RAM (hoch)
- HMI/Engineering-PC Triage (hoch)
- Netzwerk-Capture (C2) (hoch)
- Inverter/BMS/SCADA-Logs (mittel)

IR-Pilot Einsatzkarte · Reihenfolge: Sicherheit > flüchtige Beweise > Eindämmung. Asservate hashen + Chain of Custody.

HOCH

Phishing-Welle - Zugangsdaten abgegriffen

IT · Phishing / Identitaet

Mehrere Mitarbeiter haben auf eine Phishing-Mail geklickt/Zugangsdaten eingegeben; Folgeanmeldungen aus dem Ausland.

Sofortmassnahmen

1. Mail aus Postfaechern entfernen
2. Betroffene Konten zuruecksetzen
3. Anzeichen fuer Token-/Session-Diebstahl (AiTM)?

Meldewege & Fristen

- Geschaeftsleitung / Krisenstab [sofort]
- Mitarbeiter / Kunden / Oeffentlichkeit [nach Freigabe]
- Datenschutz-Aufsichtsbehoerde / DSB [binnen 72 h ab Kenntnis (Art. 33 DSGVO)]
- Polizei - Zentrale Ansprechstelle Cybercrime (ZAC) [zeitnah]

Beweise zuerst (Volatilitaet)

- Phishing-Mail + IOCs (mittel)
- Sign-in/MFA-Logs (mittel)
- Postfachregeln (mittel)

IR-Pilot Einsatzkarte · Reihenfolge: Sicherheit > fluechtige Beweise > Eindaeimmung. Asservate hashen + Chain of Custody.

KRITISCH

Wasserwerk - Manipulation der Trinkwasser-Steuerung (OT/KRITIS)

OT/ICS · Wasser (KRITIS, Gesundheit)

Auffaellige Sollwerte/Schaltzustände in der Wasseraufbereitung (z.B. Dosierung/Chlorung) - Verdacht auf Manipulation.

Sofortmassnahmen

1. Wasserqualitaet zuerst sichern
2. Akute Gesundheitsgefahr (Dosierung)?
3. Steuerung beobachten, nicht voreilig kappen

Meldewege & Fristen

- Geschaeftsleitung / Krisenstab [sofort]
- Gesundheitsamt (Trinkwasser) [unverzueglich bei Qualitaetsgefahr]
- BSI (+ BNetzA, CERT) [unverzueglich (§8b BSIG / sektorspezifisch)]
- Polizei - Zentrale Ansprechstelle Cybercrime (ZAC) [zeitnah]

Beweise zuerst (Volatilitaet)

- HMI/Engineering Triage (hoch)
- PLC-Programm/Parameter (mittel)
- OT-Capture (pcap) (hoch)

IR-Pilot Einsatzkarte · Reihenfolge: Sicherheit > fluechtige Beweise > Eindaeimmung. Asservate hashen + Chain of Custody.

KRITISCH

Cloud/M365 - Tenant-Uebernahme (Global Admin)

Cloud · Identitaet (M365/Entra)

Verdacht auf Uebernahme des M365/Entra-Tenants: neue Global Admins, OAuth-Consent, fremde Mailregeln/Exfiltration.

Sofortmassnahmen

1. Break-Glass-Konto sichern & nutzen
2. Sessions/Token der Admins widerrufen
3. Boesartige OAuth-App / Service Principal?

Meldewege & Fristen

- Geschaeftsleitung / Krisenstab [sofort]
- Datenschutz-Aufsichtsbehoerde / DSB [binnen 72 h ab Kenntnis (Art. 33 DSGVO)]
- Polizei – Zentrale Ansprechstelle Cybercrime (ZAC) [zeitnah]
- Mitarbeiter / Kunden / Oeffentlichkeit [nach Freigabe]

Beweise zuerst (Volatilitaet)

- M365/Entra Audit-Logs (mittel)
- OAuth-Grants/Service Principals (mittel)
- Rollen/Federation-Aenderungen (mittel)
- Exfil-/Regel-Indikatoren (mittel)

IR-Pilot Einsatzkarte · Reihenfolge: Sicherheit > fluechtige Beweise > Eindaeimmung. Asservate hashen + Chain of Custody.